

Aula 1 (Módulo 04) — IDS, IPS, NIDS e NIPS

1. IDS vs. IPS — detectar vs. bloquear

Já vimos firewall (Módulo 03, Aula 6): ele decide **o que pode passar** com base em regras relativamente simples (IP, porta, protocolo). IDS e IPS vão além — eles analisam o **conteúdo e o padrão** do tráfego, procurando sinais de ataque conhecidos ou comportamento anômalo.

- **IDS** (*Intrusion Detection System*): **detecta** e **alerta**, mas não bloqueia por si só — o tráfego continua passando, e um alerta é gerado para um analista investigar.
- **IPS** (*Intrusion Prevention System*): faz a mesma análise, mas **bloqueia ativamente** o tráfego identificado como malicioso, em tempo real, sem esperar um humano decidir.

Por que importa para segurança: essa diferença é uma decisão de trade-off real em qualquer ambiente: IPS pode bloquear ataques automaticamente (resposta mais rápida), mas um **falso positivo** em modo IPS pode derrubar tráfego legítimo (ex.: bloquear um cliente real por engano) — enquanto um IDS é mais seguro nesse sentido, mas depende de alguém (ou de automação) agir sobre o alerta a tempo. Muitos ambientes rodam em modo IDS primeiro, ajustam as regras (reduzindo falsos positivos) e só depois migram partes para modo IPS — chamado de "tuning", que vamos formalizar no Módulo 21 (Detection Engineering).

2. NIDS vs. HIDS (e NIPS vs. HIPS) — onde a detecção acontece

O "N" e o "H" indicam **onde** o sistema observa:

- **NIDS/NIPS** (*Network-based*): observa o **tráfego de rede**, tipicamente posicionado em um ponto estratégico (ex.: na borda da rede, ou espelhando o tráfego de um switch) — vê tudo que passa por ali, de qualquer host.
- **HIDS/HIPS** (*Host-based*): roda **dentro** de um host específico, observando o que acontece naquela máquina (processos, arquivos, chamadas de sistema) — o Sysmon que vimos no Módulo 02 é, na prática, uma peça de telemetria que alimenta esse tipo de detecção baseada em host, e o Módulo 10 (EDR) aprofunda essa camada.

NIDS/NIPS → vê o TRÁFEGO que passa pela rede (não enxerga dentro de conexões criptografadas sem inspeção adicional)

HIDS/HIPS → vê o que acontece DENTRO de um host específico (processos, arquivos, syscalls)

Por que importa para segurança: as duas camadas são **complementares**, não substitutas — um ataque que usa TLS (Módulo 03, Aula 7) esconde o conteúdo do NIDS (que só vê o tráfego criptografado "de fora", sem conseguir ler o conteúdo sem inspeção TLS adicional), mas o mesmo ataque, ao executar código na máquina, ainda deixa rastro visível para um HIDS/EDR. É por isso que um SOC maduro combina as duas — nenhuma sozinha é suficiente.

3. Como IDS/IPS detectam — duas abordagens

Baseado em assinatura (signature-based)

Compara o tráfego com um banco de **padrões conhecidos** de ataques já catalogados (parecido com como um antivírus tradicional funciona). Rápido e com poucos falsos positivos para ameaças **já conhecidas**, mas não detecta nada **novo** (zero-day) que ainda não tenha assinatura.

Baseado em anomalia (anomaly-based)

Aprende (ou é configurado com) um **padrão de comportamento normal** da rede, e alerta quando algo foge desse padrão — mesmo sem uma assinatura específica para aquilo. Consegue pegar ataques novos, mas tende a gerar mais **falsos positivos**, porque "normal" pode variar bastante de ambiente para ambiente.

Por que importa para segurança: ferramentas reais (Suricata, Zeek, que veremos nas próximas aulas) tipicamente combinam as duas abordagens. Entender essa distinção também explica por que um IDS/IPS **nunca é 100% suficiente sozinho** — é uma camada a mais de defesa em profundidade (*defense in depth*), não uma solução única.

4. Conectando com o que já vimos

```
Firewall (Módulo 03) → decide COM BASE EM IP/PORTA/PROTOCOLO
IDS/IPS (esta aula) → decide COM BASE NO CONTEÚDO/PADRÃO do tráfego
├─ NIDS/NIPS → observa a REDE
└─ HIDS/HIPS → observa o HOST (conecta com Sysmon/EDR)
    ├─ assinatura → detecta ameaças CONHECIDAS
    └─ anomalia → detecta desvios do NORMAL, inclusive ameaças novas
```

5. Exercício de reflexão

Retome o cenário do Módulo 02, Aula 5 (documento Word malicioso → PowerShell `-enc` → tarefa agendada de persistência):

1. Um NIDS analisando só o tráfego de rede conseguiria detectar a execução do PowerShell malicioso diretamente? Por quê?
2. Um HIDS/EDR rodando na máquina da vítima conseguiria? Com base em qual telemetria que já estudamos?
3. Se o segundo estágio do malware for baixado via HTTPS, isso muda a resposta da pergunta 1?

(Tente responder com o que já sabemos antes de seguir — vamos revisitar esse mesmo cenário com mais ferramentas nos próximos módulos.)

6. Recapitulando

- IDS detecta e alerta; IPS detecta e **bloqueia** ativamente — trade-off entre resposta automática e risco de falso positivo impactante.
- NIDS/NIPS vê a rede; HIDS/HIPS vê dentro do host — camadas complementares, não substitutas.
- Detecção por assinatura pega o conhecido com precisão; detecção por anomalia pega o desconhecido, com mais ruído.

Próxima aula

Wireshark, Zeek e Suricata — as ferramentas reais que implementam NIDS/NIPS (e captura/análise de tráfego) na prática.

Fontes recomendadas

- **NIST SP 800-94 — "Guide to Intrusion Detection and Prevention Systems (IDPS)"**: referência oficial e completa sobre tipos e arquiteturas de IDS/IPS. <https://csrc.nist.gov/pubs/sp/800/94/final>